

GUÍA METODOLÓGICA INTEGRAL

Cálculo de IGM, Análisis, ROI y Recomendaciones

Versión: 1.0

Fecha: Enero 2026

Audiencia: CISOs, Responsables GRC, Auditores, Consultores de Ciberseguridad

Metodología: GQM (Goal-Question-Metric) + NIST CSF 2.0 + FAIR + Modelo de Madurez INCIBE

1. INTRODUCCIÓN METODOLÓGICA

1.1 Marco Teórico: Modelo GQM

La **Metodología GQM (Goal-Question-Metric)** establece un enfoque jerárquico para medir ciberseguridad:

NIVEL 1 (ESTRATÉGICO): METAS

↓

NIVEL 2 (TÁCTICO): PREGUNTAS (Objetivos específicos)

↓

NIVEL 3 (OPERACIONAL): MÉTRICAS (Datos cuantitativos)

En el contexto de esta encuesta:

- Metas: Evaluar madurez cibernética según NIST CSF 2.0 (Gobernar, Identificar, Proteger, Detectar, Responder, Recuperar)
- Preguntas: Secciones 2-11 de la encuesta (preguntas específicas sobre implementación de controles)
- Métricas: Respuestas escaladas (0-5) que componen el Índice Global de Madurez (IGM)

1.2 Alineación con Estándares

Estándar	Cobertura en Encuesta	Nivel
NIST CSF 2.0	100% (6 funciones base)	Estratégico
NIST SP 800-171	60% (controles críticos DoD)	Táctico
ISO 27001:2022	80% (14 dominios cubiertos)	Táctico
NIS2 (Directiva UE)	100% (requisitos esenciales)	Regulatorio
CMMC 2.0	50% (niveles 1-2 cubiertos)	Certificación
FAIR	100% (Sección 12: cuantificación de riesgos)	Análisis de Riesgos
ENS (España)	100% (requisitos públicos)	Normativo
CRA (Ley Ciberresiliencia UE)	70% (productos digitales)	Regulatorio

2. CÁLCULO DEL ÍNDICE GLOBAL DE MADUREZ (IGM)

2.1 Fórmula Base del IGM

$$\text{IGM} = (\text{Puntuación GV} + \text{Puntuación ID} + \text{Puntuación PR} + \text{Puntuación DE} + \text{Puntuación RS} + \text{Puntuación RC}) / 6$$

Donde:

- **GV (Gobernar)**: Secciones 2 + 3 (gobernanza, riesgos)
- **ID (Identificar)**: Secciones 3 + 10 (vulnerabilidades, supply chain)
- **PR (Proteger)**: Secciones 4 + 5 + 8 + 11 (controles técnicos, entrenamiento)
- **DE (Detectar)**: Sección 5 (SIEM, monitorización)
- **RS (Responder)**: Sección 6 (incidentes, comunicación)
- **RC (Recuperar)**: Sección 9 (continuidad, DR)

2.2 Escala de Madurez y Conversión

Respuestas de Encuesta – Puntuación Numérica (0-5):

Para cada pregunta multi-opción:

- [] **Opción A** → 0 puntos (Inexistente)
- [] **Opción B** → 1 punto (Inicial)
- [] **Opción C** → 2 puntos (Gestionada)
- [] **Opción D** → 3 puntos (Definida)
- [] **Opción E** → 4 puntos (Optimizada)

Ejemplo Sección 2.1 (Política de Ciberseguridad):

- Respuesta marcada: "Política completa, comunicada a toda la organización, revisión anual"
- Conversión: Opción D → **3 puntos**

2.3 Cálculo por Dominio: Promedio Ponderado

Dominio GOBERNAR (GV) - Ponderación según NIST CSF:

$$\begin{aligned} \text{Puntuación GV} = & (\text{Política Ciberseguridad} \times 0.25) + \\ & (\text{Responsabilidades} \times 0.20) + \\ & (\text{Cumplimiento Normativo} \times 0.30) + \\ & (\text{Modelo Gobernanza Riesgos} \times 0.15) + \\ & (\text{Inversión Presupuesto} \times 0.10) \end{aligned}$$

Ejemplo Cálculo:

- Política: 3 puntos
- Responsabilidades: 4 puntos
- Cumplimiento: 2 puntos
- Gobernanza Riesgos: 3 puntos
- Inversión: 2 puntos

$$\text{GV} = (3 \times 0.25) + (4 \times 0.20) + (2 \times 0.30) + (3 \times 0.15) + (2 \times 0.10)$$

$$\text{GV} = 0.75 + 0.80 + 0.60 + 0.45 + 0.20 = \mathbf{2.8 \text{ puntos}}$$

Dominio IDENTIFICAR (ID) - Ponderación:

Puntuación ID =

(Inventario de Activos $\times$ 0.25) +
(Evaluación Vulnerabilidades $\times$ 0.35) +
(Ciclo de Vida Vulnerabilidades $\times$ 0.25) +
(CVSS/EPSS $\times$ 0.10) +
(Gap Analysis $\times$ 0.05)

Dominio PROTEGER (PR) - Ponderación:

Puntuación PR =

(Testing (Pentest) $\times$ 0.20) +
(Scope Testing $\times$ 0.15) +
(Resultados Testing $\times$ 0.25) +
(Controles Técnicos (Sec 8) $\times$ 0.20) +
(Entrenamiento Concienciación $\times$ 0.20)

Dominio DETECTAR (DE) - Ponderación:

Puntuación DE =

(Arquitectura SIEM $\times$ 0.30) +
(Fuentes Centralizadas $\times$ 0.25) +
(Detección Amenazas $\times$ 0.25) +
(Métricas SIEM (MTTD) $\times$ 0.15) +
(Integración Herramientas $\times$ 0.05)

Dominio RESPONDER (RS) - Ponderación:

Puntuación RS =

(Plan Respuesta Incidentes $\times$ 0.30) +
(Estructura Equipo $\times$ 0.20) +
(Notificación/Comunicación $\times$ 0.25) +
(Métricas Respuesta (MTTC) $\times$ 0.25)

Dominio RECUPERAR (RC) - Ponderación:

Puntuación RC =

(Plan DR Documentado $\times$ 0.35) +
(RTO/RPO Definido $\times$ 0.30) +
(Estrategia Backup $\times$ 0.25) +
(Pruebas Recuperación $\times$ 0.10)

2.4 IGM Final: Cálculo Agregado

$IGM = (GV + ID + PR + DE + RS + RC) / 6$

Ejemplo:

GV = 2.8

ID = 3.2

PR = 3.0

DE = 2.5

RS = 3.1

RC = 2.9

$IGM = (2.8 + 3.2 + 3.0 + 2.5 + 3.1 + 2.9) / 6 = 17.5 / 6 = 2.92$

2.5 Interpretación del IGM: Niveles de Madurez

Rango IGM	Nivel Madurez	Descripción	Riesgo Residual
1.0-1.5	Maturity 0	Caótico / Ad Hoc	Crítico (>80%)
1.6-2.4	Maturity 1	Inicial / Básico	Muy Alto (60-80%)
2.5-3.4	Maturity 2	Gestionado / Repetible	Alto (40-60%)
3.5-4.0	Maturity 3	Definido / Formalizado	Medio (20-40%)
4.1-5.0	Maturity 4	Optimizado / Adaptativo	Bajo (<20%)

Ejemplo Interpretación:

- IGM = 2.92 → **Maturity 2 (Gestionado)**
- Riesgo Residual: 40-60%
- Conclusión: Controles formalizados pero con gaps significativos. Cumplimiento básico de normativas pero sin optimización.

3. ANÁLISIS POR DOMINIO: INTERPRETACIÓN DETALLADA

3.1 Dominio GOBERNAR (Governance)

Qué Mide: Marco de gobernanza, políticas, responsabilidades ejecutivas, cumplimiento normativo

Benchmark por Tamaño Organización:

Tamaño	IGM GV Esperado	Justificación
Micro/Pequeña	2.0-2.5	Gobernanza básica, sin formalización
Mediana	2.5-3.5	Políticas formales, comité seguridad
Grande	3.5-4.0	CISO ejecutivo, gobernanza estructurada
CRITIS	4.0+	Cumplimiento obligatorio NIS2 + regulaciones

Principales Gaps Detectados Comúnmente:

- Falta de CISO con autoridad ejecutiva (directa a CEO)
- Ausencia de políticas de ciberseguridad documentadas
- Desconocimiento de requisitos NIS2/GDPR/ISO 27001
- Presupuesto insuficiente (<1% ingresos en grandes empresas)
- Comité de gobernanza débil o inexistente

Recomendaciones si IGM GV < 3.0:

1. Formalizar política de ciberseguridad (30 días)
2. Crear comité de gobernanza con C-level (60 días)

3. Nombrar CISO con autoridad ejecutiva (90 días)
4. Realizar gap analysis vs. NIST CSF 2.0 (120 días)
5. Incrementar presupuesto a 2% ingresos (2026)

3.2 Dominio IDENTIFICAR (Asset & Risk Identification)

Qué Mide: Inventario de activos, evaluación vulnerabilidades, gestión de brechas de seguridad

Benchmark por Tamaño:

Tamaño	IGM ID Esperado	Herramientas Típicas
Pequeña	2.0-2.5	Escaneo manual/Nessus básico
Mediana	2.5-3.5	Qualys/Nessus + CMDB
Grande	3.5-4.0	Plataforma VM dedicada + IA
CRITIS	4.0+	VM avanzada + FAIR + threat intel

Métricas Críticas de IDENTIFICAR:

1. Cobertura de Inventario (% activos monitorizados):

2. Target: >90%

3.

Si <70%: Gap crítico

4.

Frecuencia de Escaneo:

5. Crítico: Semanal

6. Alto: Quincenal

7.

Medio: Mensual

8.

% Vulnerabilidades Críticas:

9. Remediadas en 30 días: Target >80%

10.

Pendientes: Max 5-10

11.

Adopción de EPSS (vs. solo CVSS):

12. No adoptada: IGM ID máximo 2.5

13. Parcial: IGM ID máximo 3.5

14. Total: IGM ID potencial 4.0+

Si <70%: Gap crítico

Frecuencia de Escaneo:

Medio: Mensual

% Vulnerabilidades Críticas:

Pendientes: Max 5-10

Adopción de EPSS (vs. solo CVSS):

Recomendaciones si IGM ID < 2.8:

1. Implementar escaneo automatizado (Nessus/Qualys)

2. Establecer SLA de remediación por severidad

3. Adoptar EPSS para priorización basada en riesgo

4. Documentar exclusiones de escaneo
5. Validar post-remediación (re-testing)

3.3 Dominio PROTEGER (Defensive Controls)

Qué Mide: Pruebas de penetración, cobertura de testing, controles técnicos, capacitación

Benchmark Pentest por CRITIS:

Tipo Organización	Pentest Frecuencia	Coverage Esperado	IGM PR
No CRITIS	Anual	Perimetral	2.5-3.0
Operador Importante	Semestral	Perimetral + Internal	3.0-3.5
Operador Esencial	Trimestral + Red Team	100% (incluye OT)	3.5-4.0

Métricas de Pentest:

15. Tasa de Remediación (post-pentest):
16. Críticas en 30 días: Target >80%
17. Altas en 60 días: Target >80%
18.
 - Si <60%: Gap de capacidad respuesta
19.
 - Hallazgos por Pentest:
20. Rango típico: 15-30 hallazgos/pentest
21. Si >50: Postura débil (IGM PR <2.5)
22.
 - Si <5: Posible scope limitado
23.
 - Cobertura de Testing:
24. Solo perimetral: IGM PR máximo 2.5
25. Perimetral + interno: IGM PR máximo 3.0
26. Incluye OT/cloud/APIs: IGM PR potencial 4.0+

Si <60%: Gap de capacidad respuesta

Hallazgos por Pentest:

Si <5: Posible scope limitado

Cobertura de Testing:

Recomendaciones si IGM PR < 3.0:

1. Implementar pentest externo anual mínimo (60 días)
2. Agregar pentest interno semestral (120 días)
3. Establecer SLA remediación por severidad
4. Formalizar red team exercises (6 meses)
5. Adoptar bug bounty program (si aplicable)

3.4 Dominio DETECTAR (Detection & Monitoring)

Qué Mide: SIEM, centralización de logs, reglas de detección, MTTD

Benchmark SIEM Madurez:

Madurez	Arquitectura	Cobertura	Alertas/Día	IGM DE
Ausente	No existe	0%	0	0-1.0
Básica	SIEM manual	30-50%	5-20	1.5-2.0
Establecida	SIEM con reglas	70-90%	20-50	2.5-3.0
Avanzada	SIEM + SOAR	90-100%	10-30 (filtradas)	3.5-4.0

MTTD (Mean Time To Detect):

- Target CRITIS: <15 minutos
- Target Empresarial: <1 hora
- Actual Promedio España: 2-4 horas (datos INCIBE 2024)

Falsos Positivos (False Positive Rate):

- Target: <5% alertas
- Actual Promedio: 20-40% (sin tuning)
- Si >50%: SIEM sobrealertado, riesgo de fatigas analista

Recomendaciones si IGM DE < 2.5:

1. Implementar SIEM centralizado (90 días)
2. Conectar 90%+ fuentes de logs (120 días)
3. Crear 50+ reglas de detección básicas (150 días)
4. Optimizar alertas (reducir falsos positivos <10%) (180 días)
5. Integrar SOAR para automatización (240 días)

3.5 Dominio RESPONDER (Response & Recovery)

Qué Mide: Plan de respuesta, equipos, notificación, MTTC

Benchmark Métricas de Respuesta:

Métrica	Objetivo	Actual España (2024)	Gap
MTTC (contención)	<4 horas	6-8 horas	+50%
Notificación inicial	<24 horas	24-48 horas	+100%
Reporte preliminar	<72 horas	5-7 días	+100%
% planes formales	>90%	64% (encuestas)	-26%

Checklist Plan de Respuesta Completo:

- ☐ Procedimientos formales documentados
- ☐ Roles/responsables designados
- ☐ Plazos de notificación definidos (NIS2: 24/72/30 días)
- ☐ Equipo técnico disponible 24/7 (o SOC)
- ☐ Abogado/Legal en equipo crisis
- ☐ Executive sponsor (C-level)
- ☐ Simulacros anuales
- ☐ Feedback de incidentes integrado

Recomendaciones si IGM RS < 2.8:

1. Documentar plan formal (60 días)
2. Crear comité de crisis (30 días)
3. Designar roles (IC, Forensics, Comms)
4. Realizar simulacro (150 días)
5. Integrar con herramientas (SIEM alert – ticket)

3.6 Dominio RECUPERAR (Continuity & Recovery)

Qué Mide: DR, RTO/RPO, backups, pruebas de recuperación

Benchmark RTO/RPO por CRITIS:

Criticidad	RTO Target	RPO Target	Actualización
Crítica	≤4 horas	≤1 hora	Obligatorio DS
Alta	≤24 horas	≤4 horas	Recomendado
Media	≤72 horas	≤24 horas	Anual
Baja	≤1 semana	≤1 semana	Anual

NIS2 Requisito: RTO/RPO ≤72 horas para operadores esenciales

Backup Madurez:

Nivel	Frecuencia	Copias	Aire-Gap	Testing	IGM RC
Básico	Diaria	1	No	Nunca	1.5
Mejorado	Diaria	2	No	Anual	2.5
Sólido	Diaria + semanal	3	Sí	Mensual	3.5
Resiliente	Diaria/ semanal/ mensual	3+	Sí + segregado	Mensual	4.0

Recomendaciones si IGM RC < 2.8:

1. Formalizar RTO/RPO por aplicación (60 días)
2. Implementar backup aire-gapped (120 días)
3. Automatizar pruebas mensuales (150 días)
4. Documentar procedimientos recuperación (180 días)
5. Implementar cyber recovery separado de DR (240 días)

4. CÁLCULO DE ROI EN CIBERSEGURIDAD

4.1 Metodología ROSI (Return on Security Investment)

Fórmula Básica:

$$\text{ROSI (\%)} = (\text{Reducción Riesgo} - \text{Costo Solución}) / \text{Costo Solución} \times 100$$

Ejemplo Cuantificado:

- Riesgo teórico anual (probabilidad × impacto): €2,000,000
- Probabilidad ataque ransomware: 20%
- Impacto promedio ransomware: €10,000,000

• ALE (Annual Loss Expectation): $0.20 \times €10M = €2M$

• Reducción riesgo con solución (EDR/XDR): 80% (datos Sophos 2025)

• Riesgo mitigado: $€2M \times 0.80 = €1,600,000$

• Costo implementación EDR/XDR (1.000 endpoints):

- Licencias: €50,000/año
- Implementación: €30,000
- Training: €10,000
- Total Año 1: €90,000

ALE (Annual Loss Expectation): $0.20 \times €10M = €2M$

Reducción riesgo con solución (EDR/XDR): 80% (datos Sophos 2025)

Riesgo mitigado: $€2M \times 0.80 = €1,600,000$

Costo implementación EDR/XDR (1.000 endpoints):

Cálculo ROSI Año 1:

$$\begin{aligned} \text{ROSI} &= (\text{€1,600,000} - \text{€90,000}) / \text{€90,000} \times 100 \\ \text{ROSI} &= \text{€1,510,000} / \text{€90,000} \times 100 = 1.677\% = 1,677\% \text{ ROI} \end{aligned}$$

Payback Period: $\text{€90,000} / (\text{€1,600,000} / 365) = 20 \text{ días}$

4.2 Modelo de Cálculo por Solución Típica

EDR/XDR Implementation

Costo:

- Licencias (por endpoint): €50-100/año
 - Implementación (global): €30,000-100,000
 - Training + SOC integration: €10,000-30,000
- Total Año 1: €100,000-250,000

Beneficios (30% menos incidentes):

- Reducción tiempo detección: 60-80% (MTTD 6h → 1h)
- Reducción impacto por incidente: 60% (€500k → €200k)
- Costo evitado por incidente evitado: €1-3M
- Predicción evitar 3-5 incidentes/año: €3-15M

ROSI Esperado: 800-1,500%

SIEM Implementation

Costo:

- Licencias (EPS): €50-150/EPS (1,000-5,000 EPS típico)
 - Implementación: €50,000-200,000
 - Integration + rules: €30,000-80,000
- Total Año 1: €200,000-600,000

Beneficios (centralización logs, detección):

- Compliance audit cost reduction: 40% (€50k → €30k)
- Forensics acceleration: 50% (€100k → €50k)
- Response time improvement: 60% (MTTC 6h → 2.4h)
- Incidents detected: 2-3 más/año

ROSI Esperado: 300-600%

MFA Implementation

Costo:

- Hardware tokens/software licenses: €10-20/usuario
 - Implementación (5,000 usuarios): €50,000-100,000
 - Training: €20,000
- Total Año 1: €100,000-200,000

Beneficios:

- Compromised credential attacks reduction: 80%
- Ransomware vector reduction: 70% (lateral movement)
- Cost per compromised account: €50,000 (GDPR, recovery)
- Target: Evitar 5-10 incidentes de credenciales

ROSI Esperado: 1,000-2,000%

4.3 Modelo de Cálculo: Análisis Cuantitativo (FAIR Simplificado)

Paso 1: Identificar Escenario de Riesgo

Ejemplo: Fuga de datos de cliente en nube pública

Activo: Base de datos clientes (10,000 registros)
Vulnerabilidad: Configuración errónea S3 + credenciales weak
Amenaza: Script automático scanning buckets expuestos

Paso 2: Estimar Parámetros FAIR

Threat Event Frequency (TEF) = Probabilidad evento × año

- Capacidad atacante: Alta (automatizado)
- Frecuencia scanning: Continua
- Exposición activo: Público internet

Estimación: 5-10 eventos/año = 0.7 probabilidad anual

Threat Capability (TCap) = Sofisticación atacante

- Actor: Criminales comunes (no APT)
- Herramientas: Escaneo público (no 0-day)
- Esfuerzo: Bajo

Probabilidad explotación: 70-80%

Resistance Strength (RS) = Defensa existente

- WAF: No aplicable a cloud
- DLP: No
- Segmentación: No
- Monitorización: No SIEM

Probabilidad detección/bloqueo: 10%

Loss Magnitude (LM) = Impacto financiero

- Costo per record GDPR (España): €500-1,000
- Costo per record discovery + notification: €100-200
- Downtime reputacional: €100,000-500,000
- Multa AEPD (art. 83): €50,000-€500,000

Total potencial: €5,000,000-€10,000,000

Paso 3: Calcular ALE (Annual Loss Expectation)

LEF (Loss Event Frequency) = TEF × (1 - RS)

LEF = 0.70 × (1 - 0.10) = 0.63 eventos/año

ALE = LEF × LM

ALE = 0.63 × €7,500,000 = €4,725,000

Interpretación: Riesgo anual esperado = €4.7M

Paso 4: Evaluar Mitigación (Implementar DLP + monitoring)

Costo mitigación:

- DLP cloud solution: €80,000/año
- Implementación: €30,000
- SIEM cloud integration: €20,000

Total: €130,000/año

Reducción riesgo:

- RS improves: 10% → 70% (con DLP + monitoring)
- LEF nuevo = 0.70 × (1 - 0.70) = 0.21 eventos/año
- ALE nuevo = 0.21 × €7.5M = €1,575,000
- Reducción: €4.7M - €1.58M = €3,125,000

ROSI = (€3,125,000 - €130,000) / €130,000 × 100 = 2,404% ROI

5. ANÁLISIS COMPARATIVO Y BENCHMARKING

5.1 Matriz Comparativa: Organización vs. Benchmarks

Crear tabla para comparación:

DOMINIO	PUNTUACIÓN ACTUAL	BENCHMARK INDUSTRIA	GAP (%)	POSICIÓN vs. Pares
GV (Gobernar)	2.8	3.2	-12.5%	25 percentil
ID (Identificar)	3.2	3.0	+6.7%	75 percentil
PR (Proteger)	3.0	3.1	-3.2%	40 percentil
DE (Detectar)	2.5	3.3	-24.2%	10 percentil
RS (Responder)	3.1	3.0	+3.3%	60 percentil
RC (Recuperar)	2.9	2.8	+3.6%	65 percentil

IGM TOTAL	2.92	3.07	-4.9%	40 percentil

5.2 Benchmarking por Sector (Datos España 2024-2025)

Sector	IGM Promedio	CRITIS	Tendencia
Financiero	3.4	Sí	↑ (cumplimiento normativo)
Energía	3.1	Sí	↑ (NIS2 transposición)
Telecomunicaciones	3.3	Sí	→ (maduro)
Transporte	2.8	Sí	↑ (mejorando)
Agua	2.6	Sí	↑ (crítico)
Salud	2.9	Parcial	↑ (GDPR compliance)
Educación	2.4	No	↑ (conciencia)
Administración Pública	2.9	Sí	↑ (ENS obligatorio)
Industrial	2.5	No	↑ (supply chain)
Retail	2.3	No	↓ (blanco ransomware)

6. ANÁLISIS DE BRECHAS Y ROADMAP DE MEJORA

6.1 Matriz de Priorización: Impacto vs. Esfuerzo

IMPACTO ALTO	ESFUERZO BAJO QUICK WINS (30-60 días)	ESFUERZO ALTO STRATEGIC PROJECTS (6-12 meses)
	- MFA - Policy update - Training - Backup testing	- SIEM implementation - Red team - Zero Trust - Cloud security
IMPACTO BAJO	FILL-INS (60-90 días)	AVOID
	- Documentation - Minor controls	- Nice-to-haves - Low-risk areas

6.2 Roadmap de Mejora: Ejemplo 18 Meses

Trimestre 1 (Quick Wins - Impacto Máximo/Mínimo Esfuerzo)

- ☐ Actualizar política de ciberseguridad
- ☐ Implementar MFA universal
- ☐ Formalizar plan respuesta incidentes
- ☐ Comenzar simulaciones phishing
- Inversión esperada: €80,000-120,000
- IGM esperado post-Q1: +0.3 puntos

Trimestre 2-3 (Fortalezas - Strategic Projects)

- ☐ Implementar SIEM
- ☐ Pentest externo + remediación
- ☐ Establecer SOAR
- ☐ Capacitación especializada (roles críticos)
- Inversión esperada: €300,000-500,000
- IGM esperado post-Q3: +0.8 puntos

Trimestre 4-6 (Optimización - Sostenibilidad)

- ☐ Red team exercises
- ☐ Zero Trust iniciativa
- ☐ Disaster recovery testing
- ☐ Supply chain risk assessment
- Inversión esperada: €200,000-300,000
- IGM esperado post-Q6: +1.2 puntos

Resultado 18 Meses:

- IGM inicial: 2.92
- IGM final (proyectado): 4.12 (**Maturity 4**)
- Inversión total: €580,000-920,000
- ROI esperado: 500-1,200%

7. INDICADORES CLAVE DE RENDIMIENTO (KPI) DERIVADOS

7.1 KPI Estratégicos (C-Level / Junta)

KPI	Fórmula	Frecuencia	Target
IGM	Promedio dominio NIST	Trimestral	>3.5
Riesgo Residual (%)	$(1 - (\text{Controles} / \text{Riesgos})) \times 100$	Mensual	<30%
Exposición Económica (€)	ALE total cuantificado	Mensual	±20% YoY
Incidentes Críticos	Count incidentes severity crítica	Mensual	0
Cumplimiento Normativo (%)	$(\text{Requisitos cumplidos} / \text{Total}) \times 100$	Trimestral	>95%
ROSI (%)	$(\text{Beneficios} - \text{Costos}) / \text{Costos}$	Anual	>500%

7.2 KPI Operacionales (CISOs, Equipos)

KPI	Target	Benchmark
MTTD	<15 min (crítica)	Actual España: 2-4h
MTTC	<4 horas	Actual España: 6-8h
% vulnerabilidades remediadas	>80% críticas en 30d	Actual España: 60%
Cobertura SIEM (%)	>90%	Actual España: 60-70%
Click rate phishing	<5%	Actual España: 12-15%
Falsos positivos SIEM	<5%	Actual España: 20-40%

8. LIMITACIONES Y CONSIDERACIONES

8.1 Limitaciones Metodológicas

27. Escala 0-5 subjetiva: Requiere calibración con auditoría externa
28. Ponderaciones: Pueden variar por sector/regulación
29. Datos auto-reportados: Riesgo de sobre-optimismo (validar con evidencia documental)
30. Punto en el tiempo: IGM refleja estado en fecha de encuesta (no histórico)
31. No predice: IGM no predice si evitará incidente próximo (solo postura relativa)

8.2 Mejoras Recomendadas

- Validación externa: Auditoría independiente anual de IGM
- Correlación incidentes: Comparar IGM con histórico incidentes reales
- Benchmarking dinámico: Actualizar benchmarks trimestralmente con datos de mercado
- Análisis de confianza: Intervalos de confianza en métricas (min/esperado/máx)

REFERENCIAS METODOLÓGICAS

- NIST Cybersecurity Framework 2.0 (nvlpubs.nist.gov)
- INCIBE IMC (Indicadores Mejora Ciberresiliencia)
- Factor Analysis of Information Risk (FAIR Institute)
- ISO/IEC 27005:2022 (Risk Management)
- Directiva NIS2 (UE)
- Global Cybersecurity Index (ITU)

Fin de Guía Metodológica

Versión: 1.0 | Última actualización: Enero 2026